

Proposal dan Teknis Keamanan Informasi Pertemuan 6



Kelompok 6 K2:

Taura Mohamad Inzaghi	G6401231019
Muhammad Syafiq Romadhon	G6401231079
Muhammad Fauzan Akbar	G6401231045

**Keamanan Informasi
Program Studi Ilmu Komputer
Sekolah Sains Data, Matematika, dan Informatika
IPB University
2026**

DAFTAR ISI

DAFTAR ISI.....	2
BAB I.....	3
PENDAHULUAN	3
1.1 Latar Belakang	3
1.2 Tujuan Proyek.....	3
1.3 Ruang Lingkup.....	4
BAB II	5
ANALISIS RISIKO (THREAT MODELING).....	5
2.1 Identifikasi Ancaman Keamanan.....	5
2.2 Brute-force Attack	5
2.4 Session Hijacking.....	6
2.5 Cross-Site Scripting (XSS)	6
2.6 Ringkasan Mitigasi Ancaman	7
BAB III.....	8
DESAIN PROTOKOL KEAMANAN	8
3.1 Protokol Autentikasi Pengguna.....	8
3.2 Protokol Reset Password dengan OTP	9
3.3. Protokol Akses Modul Admin	9
3.4. Protokol Pengambilan Data Produk.....	10
3.5. Protokol Komunikasi Chat.....	11

BAB I

PENDAHULUAN

1.1 Latar Belakang

Perkembangan teknologi informasi telah mendorong banyak perusahaan untuk melakukan transformasi digital dalam berbagai aspek operasional bisnis, termasuk pemasaran, administrasi, dan pelayanan kepada pelanggan. Salah satu bentuk transformasi tersebut adalah pemanfaatan aplikasi berbasis web yang memungkinkan perusahaan untuk menjangkau pasar yang lebih luas serta meningkatkan efisiensi pengelolaan data dan transaksi.

Jatibahagya merupakan perusahaan yang bergerak di bidang produksi dan penjualan furnitur berbahan kayu jati. Saat ini proses pemasaran dan administrasi pada perusahaan tersebut masih dilakukan secara manual sehingga menimbulkan berbagai kendala, seperti keterbatasan jangkauan pemasaran, pengelolaan data produk yang kurang efisien, serta proses komunikasi dengan pelanggan yang belum terintegrasi secara digital. Kondisi ini dapat menghambat perkembangan bisnis serta menurunkan daya saing perusahaan di era digital.

Untuk mengatasi permasalahan tersebut, diperlukan sebuah sistem berbasis web yang dapat mendukung kegiatan pemasaran dan pengelolaan produk secara lebih efektif. Oleh karena itu dirancang sebuah aplikasi Jatibahagya WebApp, yaitu sebuah platform e-commerce yang memungkinkan perusahaan untuk menampilkan katalog produk, melakukan pengelolaan data produk secara digital, serta memfasilitasi komunikasi antara pelanggan dan pihak perusahaan melalui fitur chat.

Namun, dalam pengembangan sistem berbasis web, aspek keamanan informasi menjadi hal yang sangat penting untuk diperhatikan. Data pengguna seperti username, password, serta isi percakapan pada fitur chat merupakan informasi yang bersifat sensitif dan berpotensi disalahgunakan apabila tidak dilindungi dengan mekanisme keamanan yang memadai. Oleh karena itu, sistem perlu dilengkapi dengan mekanisme enkripsi pada proses autentikasi login serta komunikasi pada fitur chat agar data yang dikirimkan melalui jaringan tetap terlindungi dari ancaman penyadapan maupun manipulasi data.

Dengan adanya sistem Jatibahagya WebApp yang dilengkapi dengan mekanisme keamanan enkripsi, diharapkan proses pemasaran produk dapat dilakukan secara lebih luas, pengelolaan data menjadi lebih efisien, serta keamanan data pengguna dapat terjaga dengan baik.

1.2 Tujuan Proyek

Tujuan dari pengembangan sistem Jatibahagya WebApp adalah sebagai berikut:

1. Mengembangkan aplikasi web yang dapat digunakan sebagai platform e-commerce untuk memasarkan produk furnitur Jatibahagya secara online.
2. Mempermudah pengelolaan data produk dan administrasi penjualan melalui sistem berbasis web yang terintegrasi.
3. Menyediakan fitur komunikasi antara pengguna dan pihak perusahaan melalui fitur chat pada aplikasi.

4. Meningkatkan keamanan sistem dengan menerapkan mekanisme enkripsi pada proses login dan komunikasi chat untuk melindungi data pengguna.
5. Meningkatkan efisiensi operasional dan memperluas jangkauan pemasaran perusahaan melalui pemanfaatan teknologi digital.

1.3 Ruang Lingkup

Ruang lingkup pengembangan sistem dalam proyek ini meliputi beberapa batasan sebagai berikut:

1. Sistem yang dikembangkan berupa aplikasi web e-commerce Jatibahagya yang dapat diakses melalui browser.
2. Sistem menyediakan fitur utama seperti:
 - Registrasi dan login pengguna
 - Manajemen produk oleh admin
 - Tampilan katalog produk bagi pengguna
 - Fitur chat antara pengguna dan admin
3. Sistem menerapkan mekanisme autentikasi pengguna untuk memastikan bahwa hanya pengguna yang terdaftar yang dapat mengakses fitur tertentu.
4. Keamanan sistem difokuskan pada:
 - Enkripsi data pada proses login (password protection).
 - Enkripsi pesan pada fitur chat untuk menjaga kerahasiaan komunikasi.
5. Sistem tidak mencakup integrasi dengan sistem pembayaran online eksternal pada tahap pengembangan awal.
6. Pengembangan sistem difokuskan pada perancangan perangkat lunak, implementasi fitur utama, serta penerapan mekanisme keamanan dasar pada sistem.

BAB II

ANALISIS RISIKO (THREAT MODELING)

2.1 Identifikasi Ancaman Keamanan

Dalam pengembangan aplikasi berbasis web, keamanan sistem merupakan aspek penting yang harus diperhatikan sejak tahap perancangan. Sistem yang terhubung dengan jaringan internet memiliki potensi terhadap berbagai jenis serangan yang dapat mengancam kerahasiaan, integritas, dan ketersediaan data.

Pada sistem Jatibahagya WebApp, terdapat beberapa komponen yang berpotensi menjadi target serangan, seperti fitur autentikasi login, pengelolaan data pengguna, serta fitur komunikasi chat antara pengguna dan admin. Oleh karena itu diperlukan proses threat modeling untuk mengidentifikasi kemungkinan ancaman keamanan yang dapat terjadi.

Beberapa ancaman keamanan yang berpotensi terjadi pada sistem ini antara lain Brute-force Attack, SQL Injection, Session Hijacking, dan Cross-Site Scripting (XSS).

2.2 Brute-force Attack

1. Deskripsi Ancaman

Brute-force attack merupakan teknik serangan yang dilakukan dengan mencoba berbagai kombinasi username dan password secara berulang hingga berhasil mendapatkan kredensial yang valid. Serangan ini biasanya menargetkan sistem autentikasi login.

Pada sistem Jatibahagya WebApp, fitur login dapat menjadi target brute-force attack apabila tidak dilengkapi dengan mekanisme perlindungan yang memadai.

2. Dampak Serangan

Jika serangan brute-force berhasil dilakukan, maka penyerang dapat memperoleh akses tidak sah ke akun pengguna atau administrator. Hal ini dapat mengakibatkan pencurian data, manipulasi informasi produk, maupun penyalahgunaan akun.

3. Mitigasi

Untuk mengurangi risiko brute-force attack, sistem menerapkan beberapa mekanisme pengamanan, antara lain:

- Enkripsi password menggunakan algoritma hashing sehingga password tidak disimpan dalam bentuk plaintext di database.
- Pembatasan jumlah percobaan login (login attempt limit) untuk mencegah percobaan login berulang dalam waktu singkat.
- Penggunaan CAPTCHA pada proses login setelah beberapa kali percobaan gagal.
- Penerapan HTTPS untuk melindungi transmisi data login dari penyadapan.

2.3 SQL Injection

1. Deskripsi Ancaman

SQL Injection merupakan teknik serangan yang memanfaatkan celah keamanan pada input pengguna untuk menyisipkan perintah SQL berbahaya ke dalam query database. Serangan ini dapat terjadi apabila sistem tidak melakukan validasi atau sanitasi input dengan benar.

Dalam sistem Jatibahagya WebApp, potensi SQL Injection dapat terjadi pada fitur login, pencarian produk, maupun pengelolaan data oleh admin.

2. Dampak Serangan

Serangan SQL Injection dapat memungkinkan penyerang untuk:

- Mengakses data sensitif dari database
- Mengubah atau menghapus data
- Melewati proses autentikasi login

Hal ini dapat menyebabkan kebocoran data pengguna maupun kerusakan data sistem.

3. Mitigasi

Beberapa langkah mitigasi yang diterapkan dalam sistem antara lain:

- Menggunakan prepared statement atau parameterized query untuk mencegah injeksi perintah SQL.
- Melakukan validasi dan sanitasi input pengguna sebelum diproses oleh sistem.
- Membatasi hak akses database berdasarkan prinsip least privilege.
- Melakukan filter karakter khusus yang berpotensi digunakan dalam injeksi SQL.

2.4 Session Hijacking

1. Deskripsi Ancaman

Session hijacking merupakan serangan yang dilakukan dengan mengambil alih session pengguna yang sedang aktif. Penyerang dapat memperoleh session ID melalui berbagai cara, seperti penyadapan jaringan atau eksploitasi celah keamanan pada aplikasi web.

Jika session pengguna berhasil dicuri, penyerang dapat bertindak seolah-olah sebagai pengguna yang sah tanpa perlu mengetahui username dan password.

2. Dampak Serangan

Dampak dari session hijacking antara lain:

- Akses tidak sah ke akun pengguna
- Penyalahgunaan fitur sistem
- Pengubahan atau penghapusan data penting

3. Mitigasi

Untuk mengurangi risiko session hijacking, sistem menerapkan beberapa mekanisme pengamanan, yaitu:

- Menggunakan HTTPS untuk mengenkripsi komunikasi antara client dan server.
- Menggunakan session ID yang bersifat acak dan sulit ditebak.
- Menerapkan session timeout sehingga session akan otomatis berakhir setelah periode tidak aktif.
- Menggunakan atribut keamanan pada cookie seperti HttpOnly dan Secure.

2.5 Cross-Site Scripting (XSS)

1. Deskripsi Ancaman

Cross-Site Scripting (XSS) merupakan serangan yang memungkinkan penyerang menyisipkan script berbahaya ke dalam halaman web yang kemudian dijalankan di browser pengguna lain. Serangan ini biasanya terjadi pada aplikasi yang menerima input dari pengguna tanpa melakukan validasi atau penyaringan yang memadai.

Pada sistem Jatibahagya WebApp, potensi serangan XSS dapat terjadi pada fitur chat atau form input lainnya seperti pencarian produk.

2. Dampak Serangan

Jika serangan XSS berhasil dilakukan, maka penyerang dapat:

- Mencuri cookie atau session pengguna
- Mengalihkan pengguna ke situs berbahaya
- Menjalankan script berbahaya pada browser pengguna

3. Mitigasi

Untuk mencegah serangan XSS, sistem menerapkan beberapa langkah pengamanan, yaitu:

- Melakukan validasi dan sanitasi input pengguna sebelum ditampilkan kembali pada halaman web.
- Menggunakan escaping karakter HTML untuk mencegah eksekusi script.
- Menerapkan Content Security Policy (CSP) untuk membatasi sumber script yang dapat dijalankan pada halaman web.
- Menghindari penggunaan fungsi yang dapat mengeksekusi kode secara langsung dari input pengguna.

2.6 Ringkasan Mitigasi Ancaman

Secara keseluruhan, sistem Jatibahagya WebApp dirancang dengan mempertimbangkan berbagai potensi ancaman keamanan yang umum terjadi pada aplikasi web. Dengan menerapkan mekanisme pengamanan seperti enkripsi data, validasi input, penggunaan HTTPS, serta pengelolaan session yang aman, sistem diharapkan mampu meminimalkan risiko serangan dan menjaga keamanan data pengguna.

BAB III

DESAIN PROTOKOL KEAMANAN

Dalam rangka mengimplementasikan mitigasi ancaman terhadap sistem Jatibahagya WebApp, peneliti merancang sejumlah protokol keamanan, yaitu:

1. Protokol autentikasi pengguna;
2. Protokol reset password dengan OTP;
3. Protokol akses modul admin;
4. Protokol pengambilan data produk; dan
5. Protokol komunikasi chat.

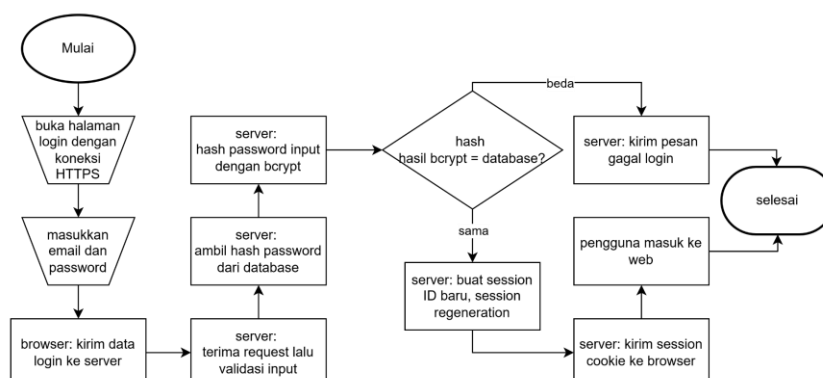
Protokol-protokol ini dirancang untuk memastikan kerahasiaan, integritas, dan autentikasi dalam setiap proses transaksi sistem.

3.1 Protokol Autentikasi Pengguna

Protokol autentikasi pengguna digunakan untuk memverifikasi identitas pengguna sebelum pengguna dapat mengakses sistem. Tujuan dari protokol ini adalah memastikan hanya pengguna yang sah yang dapat masuk ke sistem, melindungi password pengguna, serta menghindari serangan berupa session hijacking dan brute force. Protokol ini terdiri dari mekanisme hash terhadap password, pembuatan session ID secara acak, cookie dengan atribut HTTPOnly, dan rate limiting untuk mencegah brute force.

Alur protokol:

1. Pengguna membuka halaman login melalui koneksi HTTPS.
2. Pengguna memasukkan email dan password.
3. Browser mengirimkan data login ke server menggunakan metode POST.
4. Server menerima request dan melakukan validasi input.
5. Server mengambil hash dari database
6. Server melakukan hash password menggunakan algoritma bcrypt.
7. Server mencocokkan hash password dengan data yang tersimpan pada database.
8. Jika cocok, server akan:
 - a. membuat session ID baru
 - b. melakukan session regeneration
9. Server mengirimkan session cookie yang aman pada browser pengguna.
10. Pengguna berhasil masuk ke web.



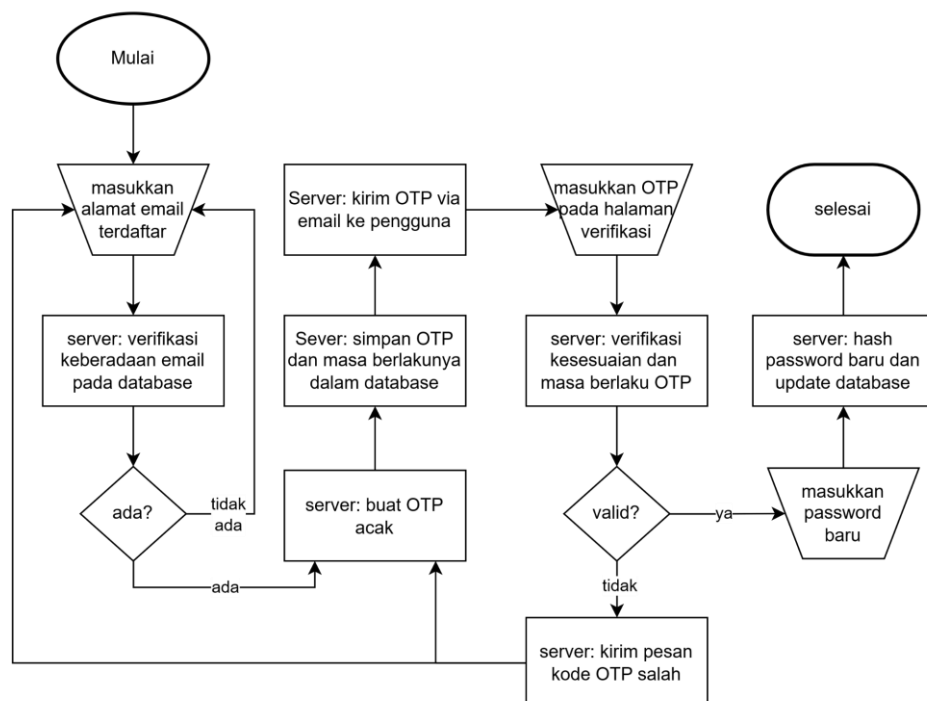
Gambar 1. Flowchart protokol autentikasi pengguna

3.2 Protokol Reset Password dengan OTP

Protokol reset password dengan OTP digunakan untuk memastikan bahwa proses penggantian password dapat dilakukan oleh pemilik akun yang sah. Tujuan dari protokol ini adalah memverifikasi identitas pengguna sebelum reset password dan menghindari pengambilalihan akun. Protokol ini terdiri dari mekanisme OTP sementara atau time-based dan sekali pakai serta password disimpan dalam bentuk hash.

Alur protokol:

1. Pengguna memilih fitur lupa password.
2. Pengguna memasukkan alamat email terdaftar.
3. Server memverifikasi keberadaan email pada database.
4. Server menghasilkan OTP secara acak.
5. Server menyimpan OTP dalam database dengan masa berlaku tertentu.
6. Server mengirim OTP kepada pengguna melalui email.
7. Pengguna memasukkan OTP pada halaman verifikasi.
8. Server memverifikasi:
 - a. kesesuaian OTP
 - b. masa berlaku OTP
9. Jika OTP valid, pengguna dapat memasukkan password baru.
10. Server melakukan hash password baru dan memperbarui database.



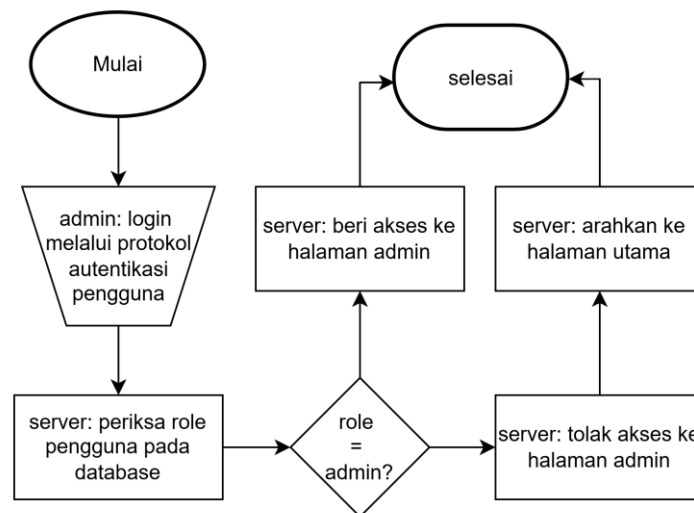
Gambar 2. Flowchart protokol reset password dengan OTP

3.3. Protokol Akses Modul Admin

Protokol akses modul admin mengatur akses terhadap fitur yang hanya boleh digunakan oleh admin. Fitur yang hanya boleh digunakan admin adalah fitur administratif, seperti manajemen produk dan pengelolaan data. Tujuan dari protokol ini adalah membatasi mencegah pengguna biasa mengakses fitur administratif. Protokol ini terdiri dari mekanisme Role Based Access Control (RBAC), middleware otorisasi laravel, dan validasi session sebelum setiap request.

Alur protokol:

1. Admin melakukan login melalui protokol autentikasi pengguna
2. Server memeriksa role pengguna pada database
 - a. Jika role pengguna adalah admin, server memberikan akses ke halaman admin
 - b. Jika bukan admin, server menolak akses dan mengarahkan ke halaman utama



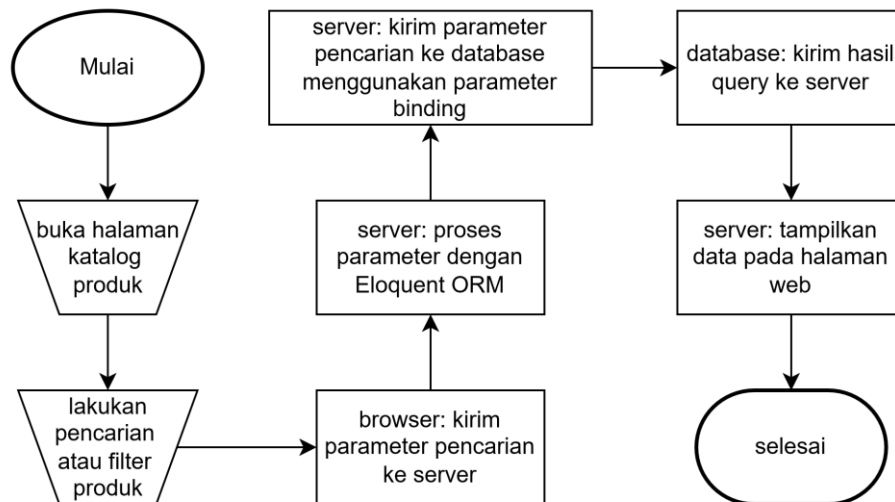
Gambar 3. Flowchart protokol akses modul admin

3.4. Protokol Pengambilan Data Produk

Protokol pengambilan data produk digunakan untuk menampilkan katalog produk kepada pengguna dengan aman. Tujuan dari protokol ini adalah melindungi sistem dari SQL injection dan menjamin integritas data yang ditampilkan. Protokol ini terdiri dari mekanisme query dengan ORM laravel, parameter binding untuk pengiriman query ke database, dan escaping otomatis pada output HTML. Protokol ini mencegah SQL injection dan Cross-Site Scripting (XSS).

Alur protokol:

1. Pengguna membuka halaman katalog produk
2. Pengguna melakukan pencarian atau filter produk
3. Browser mengirimkan parameter pencarian ke server
4. Server memproses parameter menggunakan Eloquent ORM
5. Query dikirim ke database menggunakan parameter binding
6. Database mengirimkan hasil query ke server
7. Server menampilkan data pada halaman web



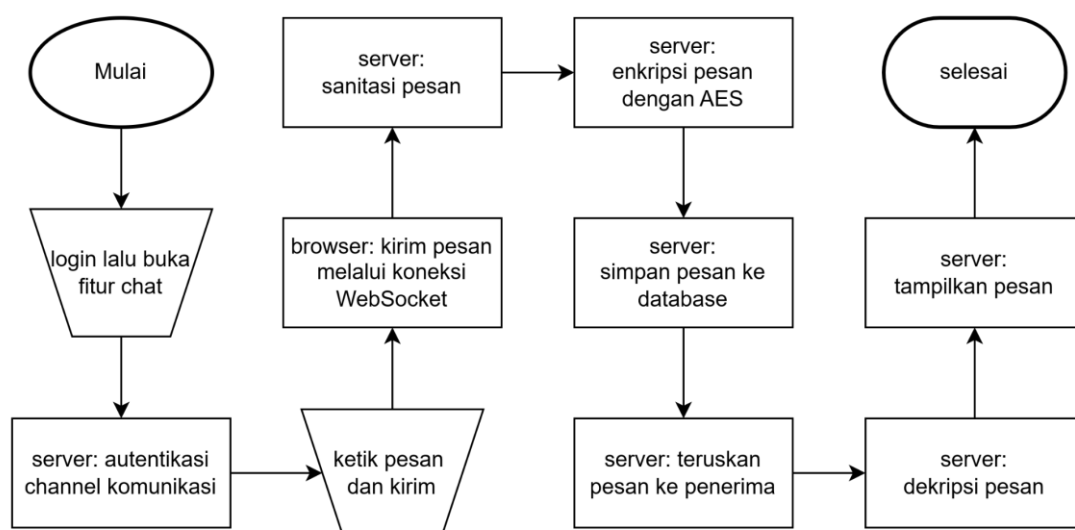
Gambar 4. Flowchart protokol pengambilan data produk

3.5. Protokol Komunikasi Chat

Protokol komunikasi chat digunakan dalam usaha menjaga privasi chat antara penjual dan pembeli. Tujuan dari protokol ini adalah menjamin kerahasiaan pesan dan mencegah injeksi skrip berbahaya. Protokol ini terdiri dari mekanisme enkripsi pesan menggunakan AES dan sanitasi input untuk cegah Cross-Site Scripting.

Alur protokol:

1. Pengguna membuka fitur chat setelah login
2. Sistem melakukan autentikasi channel komunikasi.
3. Pengguna mengetik pesan pada antarmuka chat.
4. Pesan dikirim ke server melalui koneksi WebSocket.
5. Server melakukan sanitasi pesan untuk menghilangkan skrip berbahaya.
6. Pesan dienkripsi dengan AES sebelum disimpan ke database.
7. Server meneruskan pesan ke penerima (admin atau pengguna lain).
8. Server mendekripsi pesan sebelum ditampilkan pada antarmuka chat penerima.



Gambar 4. Flowchart protokol komunikasi chat